YOUR GOALS OUR PRIORITY

FINANCEFIRST

CREDIT UNION

Incident Report

Incident Type: Ransomware Attack

Report Version: 1.0

Report Date: 12-December-2025

Prepared By: Computer Security Incident Response Team (CSIRT)

Table of Contents

1. Executive Summary 2
2. Overview of Incident 2
3. High-Level Incident Timeline 3
4. Impact Analysis 4
5. Root Cause Analysis (Five Whys) 4
6. What Went Well - Strengths 5
7. What Didn't Go Well/Gaps 5
8. Stakeholder's Feedback 5
9. Recommendations for Improvement 6
10. Action Plan 7
11. Metrics & KPIs 7
12. Regulatory Communication 8
13. Conclusion 8

1. Executive Summary

On ***Monday at 6:45 AM***, the organization experienced a ransomware attack that was the result of a phishing email that evaded email security controls and initially compromised a user workstation. For three weeks, the attacker had conducted a series of subtle reconnaissance activities, privilege escalation using stolen domain administrator credentials, and movement within multiple systems.

The attack was brought to a close with the execution of ransomware across multiple servers, which had encrypted data on production and backups. Core banking operations, digital channels hosted in the cloud, and customer-facing services were not affected because of proper network segmentation and isolation in the cloud.

Once the detection occurred, containment was quickly initiated by the CSIRT, forensic experts were engaged, and there was close collaboration with the executive leadership on the restoration of operations, assessment of impacted systems, and addressing regulatory reporting requirements. This FIR consolidates all findings, analyses, response actions, and recommendations for improvement.

2. Overview of Incident

Item	Details
Incident Type	Ransomware Attack
Initial Compromise Date	*Three weeks before detection*
Detection Date/Time	Monday, 6:45 AM
Containment Start	Monday, ~7:15 AM
Full Containment Achieved	Within first 24 hours
Affected Systems	Several on-prem servers; backup server
Unaffected Systems	Core Banking System (isolated), Online Banking, Mobile Banking (cloud)
Severity Level	Critical
Regulators Notified	NCUA and State Banking Regulator

3. High-Level Incident Timeline

3.1. Day 0 – Initial Compromise

- Phishing email evaded filters → employee clicked on the link → malware was executed.

3.2. Weeks 1–3 – Undetected Attacker Dwell Time

- Reconnaissance
- Lateral movement across the network.
- Privilege Escalation Using Compromised Domain Admin Credentials
- In silent deployment, the ransomware payload is deployed silently.

3.3. Detection (Monday, 6:45 AM)

- Suspicious encryption patterns flagged.
- SOC escalated the alert to CSIRT.

3.4. Hour 0–6 (Morning)

- Activated CSIRT.
- Affected systems isolated.
- Malware propagation stopped.

3.5. Hour 6–24

- External forensic firm engaged.
- Evidence collection began.
- Initial Recovery planning

3.6. Hour 24–48

- System restoration.
- Backup evaluation: Compromised.
- Business operations stabilized.

3.7. Hour 48–72

- Lessons Learnt workshop conducted.
- Root cause analysis and improvement plan developed.

4. Impact Analysis

4.1. Business Operation Impact

- Moderate disruption to internal systems.
- No downtime for core banking or digital channels.
- Increased inquiries by members and reputational exposure.

4.2. Impact on Data

- Some production data encrypted.
- Data for backup also encrypted due to lack of segmentation/air gap.
- No confirmed exfiltration of sensitive customer information at this stage, but forensic review is still ongoing.

4.3. Financial Impact (Estimated)

- System restoration costs.
- The forensic services provided.
- Potential regulatory penalties.
- Productivity loss.
- Reputational mitigation costs.

Estimated total: Several million USD.

5. Root Cause Analysis (Five Whys)

5.1. Root Cause: Why was the ransomware attack successful?

- Phishing email evaded defenses, employee clicked link.
- The filters in email are outdated, and the training is insufficient.
- No formal process for regular tuning and phishing simulation programs.
- Security responsibilities are scattered; no governance is centralized.
- The cybersecurity program and IR plan are outdated, untested, and lacked modern controls.

5.2. Systemic Root Cause:

- Absence of a mature cybersecurity governance framework: lack of PAM, segmentation, SIEM tuning, immutable backups, structured training programs.

6. What Went Well - Strengths

1. Effective segmentation, protects the core banking system.
2. Cloud services available and fully operational.
3. Rapid containment once the incident was detected.
4. Strong executive leadership support.
5. The immediate involvement of forensic experts.
6. CSIRT kept detailed records of everything.

7. What Didn't Go Well/Gaps

1. Poor e-mail security controls.
2. No PAM solution; domain admin compromised.
3. Poor network segmentation.
4. Advanced correlation/detection rules were not present in SIEM.
5. The backup server is accessible from production.
6. An IRP existed but was never tested.
7. Poor business continuity posture in light of worst-case scenarios.

8. Stakeholder's Feedback

1. **CISO:**

   "We need major architectural upgrades: PAM, segmentation, advanced detection, immutable backups."

2. **CEO:**

   "This incident has major financial and reputational implications. What investments prevent recurrence?"

3. **General Counsel:**

   "We need solid legal checkpoints and compliance alignment.

4. **COO:**

   "Our BCP needs drastic strengthening. Core banking survived, but not by design—by luck."

9. Recommendations for Improvement

9.1. People (Training & Awareness)

- Monthly phishing simulation campaigns.
- Realistic scenario-based cybersecurity training.
- Hands-on IR training for CSIRT.
- Annual organization-wide cyber drills.

9.2. Process (Policies & Procedures)

- Update IR Plan completely: roles, authority, points of legal review.
- Introduce PAM policy.
- Introduce the concept of an immutability-focused Backup & Recovery policy.
- Formalize network segmentation and Zero Trust policies.
- Establish the governance cycle for security control tuning.

9.3. Technology (Security Controls)

- PAM implementation
- Implement network segmentation and micro-segmentation.
- Strengthen SIEM detection with behavioral analytics.
- Deploy EDR on all endpoints.
- Air-gapped and immutable backup architecture should be built.
- Harden domain controllers and privileged access pathways.

10.Action Plan

Recommendation	Owner	Timeline
PAM Rollout	InfoSec + Infrastructure	3–6 months
SIEM Rule Enhancements	SOC + InfoSec	1–2 months
Immutable Backups	Infrastructure + DR Team	2–4 months
IR Plan Update	IT Governance + InfoSec	1 month
Quarterly IR Tests	ITG	Quarterly
Network Segmentation Project	Infrastructure	4–8 months
Enterprise Phishing Drills	HR + InfoSec	Monthly
BCP Redesign	COO + DR/BCP Team	6–9 months

11.Metrics & KPIs

11.1. Incident Response Performance

- MTTD – Mean Time to Detect
- MTTR – Mean Time to Respond
- MTTC: Mean Time to Contain
- MTTR (Recovery) – Average Time to Restore Systems

11.2. KPIs for Program Maturity

- Test frequency of IR plan: target quarterly.
- Phishing simulation click rate: Target - 50% in 12 months ↓
- PAM adoption rate (target: 100% of privileged accounts).
- Recovery success rate against backups: 100% of the target.
- Reduction of SIEM false positives and accuracy of alerts.

12. Regulatory Communication

12.1. NCUA Acknowledgment

- NCUA acknowledges receipt of the Final Incident Report and has logged the case. Additional information may be requested.

12.2. State Banking Regulator Acknowledgment

- The State Banking Department has confirmed receipt of this report and will review it in accordance with applicable regulations.

12.3. Pending Follow-Up Session

- Regulators will provide follow-up session options within 3-5 business days. No date as yet confirmed.

13. Conclusion

Critical weaknesses in security governance, architecture, and monitoring capabilities were exposed by the ransomware attack. Core banking operations were fortunate to remain safe by already existing segmentation, but the incident has highlighted systemic vulnerabilities that require immediate remediation. The recommendations outlined in this FIR mean that, if followed properly, this organization can substantially improve its defensive posture, reduce the impact of incidents, and perhaps improve compliance with most regulatory requirements.